

Revisión de Seguridad - souclaude-harness

Informe técnico de revisión de seguridad · Generado el 22/07/2026 15:11 UTC

EJEMPLO ILUSTRATIVO

Este documento es un mockup de formato con datos ficticios para revisar diseño y extensión. No se ha ejecutado ningún security review real todavía. Ningún ID, hallazgo o commit mencionado aquí es real.

RESUMEN GENERAL

No se identificaron hallazgos críticos ni altos abiertos al cierre de esta revisión. Durante el proceso se detectó y corrigió 1 hallazgo de severidad alta y 2 de severidad menor; el detalle técnico de esa corrección está resumido más abajo, sin exponer código ni métodos de explotación.

Estado de la revisión

Campo	Valor
Proyecto	souclaude-harness
Estado	■ Listo para revisión de IT
Fecha de la revisión	21/07/2026
Rama	chore/PLN-002-auditoria-harness
Commit inicial	a71503f
Commit final	50f07ea
Alcance	Código de la rama indicada: endpoints, autenticación, manejo de datos, dependencias
Aprobación de IT	■ PENDING

Resumen para IT

Este documento resume el resultado de la revisión de seguridad realizada sobre el proyecto antes de su evaluación por el equipo de IT. Se ejecutó una revisión automatizada del código, se corrigieron los hallazgos de severidad alta detectados, y se repitió la revisión para confirmar que no quedaron pendientes.

IMPORTANTE

Este informe no reemplaza un pentest formal, una auditoría externa ni la validación de infraestructura de producción. Es un insumo para que IT tome su propia decisión informada sobre el paso a producción.

Sobre el proyecto

souclade-harness es un proyecto interno de automatización (Node.js) usado como harness de desarrollo asistido, con una CLI que instala skills y agentes en proyectos consumidores. La revisión cubrió el código de la rama indicada arriba, incluyendo los componentes que exponen datos o reciben entrada de usuarios o de otros procesos.

Qué se revisó y metodología

La revisión cubrió las áreas donde típicamente aparecen los problemas de seguridad más comunes:

- **Endpoints y APIs:** como reciben y procesan datos de entrada.
- **Autenticación y sesiones:** quién puede acceder a qué, y cómo se valida.
- **Manejo de datos sensibles:** contraseñas, tokens, claves y datos personales.
- **Validación de entradas:** qué pasa cuando llegan datos inesperados o maliciosos.
- **Dependencias externas:** librerías de terceros y sus vulnerabilidades conocidas.
- **Configuración y exposición:** archivos, rutas o variables que no deberían quedar accesibles.
- **Método de revisión:** comando nativo /security-review de Claude Code.
- **Ciclos de remediación SDD ejecutados:** 1.
- **Pruebas obligatorias:** suite de tests del harness (npm test) más pruebas de regresión específicas del hallazgo corregido.

Alcance, exclusiones y limitaciones

- La revisión fue automatizada, sobre el código de la rama indicada. No incluyo pruebas manuales de penetración (pentest).
- No se evaluó la infraestructura de despliegue (servidores, red, nube) ni su configuración en producción.
- No se evaluaron integraciones externas fuera del alcance del repositorio.
- Los resultados reflejan el estado del código al momento de la revisión; cambios posteriores requieren una nueva revisión.

Resultado de la revisión final

Verificación	Resultado	Nota técnica
Inyección SQL en endpoints (POST /api/tickets, GET /api/tickets/:id, POST /api/auth/login)	Sin hallazgos	Las consultas usan parámetros preparados, no concatenación de strings
Cross-Site Scripting (XSS) reflejado o almacenado	Sin hallazgos	El contenido mostrado al usuario pasa por sanitización antes de renderizarse
Secretos o credenciales expuestas en el código	Sin hallazgos	No se encontraron API keys, contraseñas ni tokens hardcodeados en el árbol revisado
Autenticación en endpoints sensibles	Sin hallazgos	Los endpoints que exponen o modifican datos exigen sesión válida antes de procesar la solicitud
Control de acceso entre usuarios (IDOR)	Sin hallazgos	Se valida el propietario del recurso antes de responder en endpoints con parámetro de ID
Validación de datos de entrada	Sin hallazgos	Los formularios y endpoints rechazan payloads fuera de esquema con error 4xx
Dependencias con vulnerabilidades conocidas (críticas o altas)	Sin hallazgos	Árbol de dependencias sin CVEs abiertos de severidad alta o crítica al cierre
Exposición de archivos o rutas internas	Sin hallazgos	No se hallaron rutas de administración ni archivos de configuración accesibles públicamente

CONFORME

Ningún hallazgo Critical o High queda abierto al cierre de esta revisión.

Resumen de hallazgos por severidad

Severidad	Iniciales	Remediados	Abiertos
Critical	0	0	0
High	1	1	0
Medium	1	1	0
Low	1	1	0
Informativo	2	-	2

Trazabilidad de hallazgos Critical/High corregidos

ID	Severidad inicial	Activo/archivo afectado	Requisito o spec	Cambio aplicado	Prueba de regresión	Estado final
SEC-2026-004	High	src/api/tickets/create.js	specs/PLN-002-auditoria-harness/spec.md #R3	Se reemplazó la construcción manual de la consulta por parámetros preparados y se agregó validación de esquema de entrada	test/security/tickets-injection.test.js	REMEDIATED

NOTA

No se eliminó ningún hallazgo de esta tabla por haber sido corregido; el historial de corrección se conserva como evidencia.

Evidencia de pruebas

Comando	Propósito	Resultado	Evidencia
npm test	Suite completa de tests del harness	PASSED	42 tests, 0 fallidos
node --test test/security/tickets-injection.test.js	Prueba de regresión para SEC-2026-004	PASSED	Confirma rechazo de payload de inyección previamente aceptado
node bin/cli.mjs verify --strict	Verifica consistencia de manifest y templates	PASSED	Sin huérfanos, rutas rotas ni críticos faltantes

Hallazgos Medium, Low e informativos pendientes

Ningún hallazgo Medium o Low permanece abierto. Se registran 2 observaciones informativas sin impacto en el estado de la revisión:

- Falta un header Content-Security-Policy explícito en las respuestas HTML (no bloqueante).
- Los mensajes de error de un endpoint interno exponen el stack trace en modo desarrollo (no aplica a producción según configuración actual).

Riesgo residual y condiciones para producción

No hay condiciones bloqueantes. Se recomienda atender las 2 observaciones informativas en una iteración futura, sin que esto condicione el paso a producción.

Recomendación para IT

1. Proceder con la evaluación estándar de IT para el paso a producción, considerando el alcance y las limitaciones descritas arriba.
2. Si el proyecto pasa a manejar datos sensibles o de producción en mayor escala, complementar esta revisión con una validación de infraestructura y, si aplica, un pentest formal.
3. Repetir esta revisión ante cambios significativos de código antes de un nuevo despliegue.

La aprobación final de producción sigue siendo responsabilidad de IT.

Índice de evidencia

- artifacts/security/2026-07-21_000000/01-initial-security-review.md
- artifacts/security/2026-07-21_000000/04-test-evidence.md
- artifacts/security/2026-07-21_000000/05-final-security-review.md

Declaración de assurance

NOTA

En la revisión final automatizada no se identificaron hallazgos Critical o High dentro del alcance y las limitaciones declaradas. Este informe habilita la evaluación final de IT, pero no sustituye un pentest formal, la validación de infraestructura de producción ni la aprobación corporativa de despliegue.